

Codeware: নিরাপত্তা (Security) অডিট রিপোর্ট

Laravel ব্যাকএন্ড (অ্যাডমিন প্যানেল, REST API, থিম/প্লাগইন) | ০৬ অক্টোবর ২০২৬

১. সারসংক্ষেপ

কোডবেসের নিরাপত্তা-সংবেদনশীল অংশ (অথেন্টিকেশন, অথরাইজেশন, ফাইল ম্যানেজার, জিপ ইনস্টল, .env এডিটর, পাবলিক API, Blade আউটপুট) পর্যালোচনা করা হয়েছে। বেশ কিছু জায়গায় আগে থেকেই শক্ত প্রতিরক্ষা আছে, তবে ২টি উচ্চ ঝুঁকি, ৪টি মাঝারি ও ৩টি নিম্ন ঝুঁকির বিষয় পাওয়া গেছে।

গুরুত্বপূর্ণ সীমাবদ্ধতা: এটি স্ট্যাটিক কোড রিভিউ। কোনো লাইভ সার্ভারে পেনিট্রেশন টেস্ট করা হয়নি, এবং সার্ভার কনফিগারেশন (Nginx/Apache, ফায়ারওয়াল, ব্যাকআপ স্টোরেজ) ও Next.js ফ্রন্টএন্ড এই পরিধির বাইরে।

#	সমস্যা	ঝুঁকি	ধরন
১	রিচ টেক্সট (পোস্ট/পণ্য বিবরণ) স্যানিটাইজ ছাড়া রেন্ডার, Stored XSS	উচ্চ	XSS / Privilege escalation
২	কোনো সিকিউরিটি হেডার ও CSP নেই	উচ্চ	Hardening
৩	পাবলিক ফর্ম API তে থ্রটল/ক্যাপচা নেই	মাঝারি	Spam / Mail-bombing
৪	অর্ডার লুকআপে রেট লিমিট নেই	মাঝারি	Enumeration
৫	Sanctum টোকেন কখনো মেয়াদোত্তীর্ণ হয় না	মাঝারি	Session / Token
৬	অ্যাডমিন = কোড চালানোর ক্ষমতা (প্লাগইন/থিম জিপ)	মাঝারি	Design risk
৭	Custom Head/Body কোড CSP ছাড়া	নিম্ন	Design risk
৮	.env এডিটরে newline ইনজেকশন সম্ভব	নিম্ন	Injection
৯	APP_ENV=developer ও সেশন কুকি হার্ডেনিং	নিম্ন	Config

২. যা আগে থেকেই ভালো (Positive findings)

- অ্যাডমিন রুটে auth + admin + mfa + activity-log মিডলওয়্যার; API অ্যাডমিন এন্ডপয়েন্টে auth:sanctum + can:access-admin।
- দুই স্তরের গেট: access-admin (admin/staff) ও access-admin-system (শুধু admin); নিষ্ক্রিয় রোল সাথে সাথে সেশন কেটে দেয়।
- লগইন, 2FA, OTP, পাসওয়ার্ড রিসেট, রেজিস্ট্রেশনে রেট লিমিট আছে; MFA ও Passkey সাপোর্ট আছে।
- FileManagerPath: path traversal ব্লক, .env/vendor/bootstrap নিষিদ্ধ, .php/.phar/.sh ইত্যাদি এক্সটেনশন পড়া ও লেখা বন্ধ; প্রতিটি মিউটেটিং অ্যাকশনে authorizeManage()।
- জিপ এক্সট্রাক্টে Zip-slip গার্ড (., অ্যাবসোলিউট পথ, ড্রাইভ লেটার), ফাইল সংখ্যা ও সাইজ লিমিট (প্লাগইন: ২০০০ ফাইল/৫০MB)।
- থিম ডিলিট/ডাউনলোডে isInstalled() যাচাই (themes/./storage ঠেকানো), ThemeAssetController এ realpath ও MIME allow-list।
- .env গিটে ট্র্যাক করা নেই (শুধু .env.example); composer audit এ কোনো পরিচিত দুর্বলতা নেই।

- রেজিস্ট্রেশনে mass-assignment নেই (শুধু name/email/password নেওয়া হয়), নতুন ইউজার কেবল customer রোল পায়।
- raw SQL এ প্যারামিটার বাইন্ডিং; অর্ডারের দাম সার্ভারে পুনর্গণনা; অর্ডার ডিটেইলে ইমেইল মিলাতে হয়।
- Chunked upload এ svg/php/htaccess ইত্যাদি এক্সটেনশন ব্লক করা।

৩. সমস্যা, প্রভাব ও সমাধান

সমস্যা ১: রিচ টেক্সট স্যানিটাইজ ছাড়া রেন্ডার, Stored XSS (ঝুঁকি: উচ্চ)

পোস্টের description, পণ্যের description/excerpt/specifications থিম ব্লোকে {!! ... !!} দিয়ে সরাসরি প্রিন্ট হয় (themes/ecommerce/product.blade.php, post.blade.php, themes/portfolio/*)। Livewire ফর্মে ভ্যালিডেশন শুধু nullable|string, আর কোডবেসে কোনো HTML স্যানিটাইজার নেই (strip_tags শুধু শব্দ গোনার জন্য)।

প্রভাব: staff রোল (শুধু কনটেন্ট লেখার অধিকার) একটি <script> বা onerror= পেলোড পণ্যের বিবরণে রাখতে পারে। কোনো admin সেই পেজ বা প্রিভিউ খুললে স্ক্রিপ্ট admin এর সেশনে চলবে, ফলে staff নিজেকে admin বানাতে পারবে (access-admin-system গেট এড়িয়ে)। এছাড়া সাধারণ ভিজিটরদের ওপর স্ক্রিপ্ট চলবে (কার্ড চুরি, রিডাইরেক্ট)।

সমাধান:

1. HTMLPurifier (mews/purifier) যোগ করুন এবং সেভ করার সময় ও রেন্ডারের সময় দুই জায়গাতেই allowlist নীতিতে স্যানিটাইজ করুন (p, a[href], img[src,alt], ul/ol/li, h2-h4, strong/em, table ইত্যাদি)।
2. স্ক্রিপ্ট, iframe, on* অ্যাট্রিবিউট ও javascript: URL সম্পূর্ণ বাদ দিন; href এ শুধু http/https/mailto/tel।
3. Blade এ সরাসরি {!! !!} এর বদলে একটি হেল্পার/ডিরেকটিভ (@richtext(\$post->description)) ব্যবহার করুন যা ভেতরে স্যানিটাইজ করে।
4. মডেলের mutator বা Livewire ফর্মের save() এ একবারই স্যানিটাইজ করুন, যাতে পুরোনো ডাটা পরিষ্কার করতে একটি artisan কমান্ড চালানো যায়।
5. এর সাথে সমস্যা ২ (CSP) যোগ করলে সুরভিত্তিক সুরক্ষা হবে।

```
// app/Support/Html.php
public static function clean(?string $html): string
{
    return $html === null ? '' : clean($html, 'rich'); // config/purifier.php এর 'rich' প্রোফাইল
}

// Blade
<div class="rich-text">{!! \App\Support\Html::clean($product->description) !!}</div>
```

একই কাজ প্রযোজ্য: JSON-LD (\$document, _seo-meta) ও ইমেইল টেমপ্লেটের \$bodyHtml/\$subjectLine, যেগুলোতে ব্যবহারকারীর ইনপুট ঢুকলে HTML escape (e()) বা json_encode(JSON_HEX_TAG) নিশ্চিত করুন।

সমস্যা ২: সিকিউরিটি হেডার ও CSP নেই (ঝুঁকি: উচ্চ)

কোডবেসে Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Strict-Transport-Security কোনোটিই সেট করা নেই (ওয়েব সার্ভারে সেট করা থাকলে ভিন্ন কথা, সেটি যাচাই করুন)। ফলে ক্লিকজ্যাকিং, MIME sniffing ও XSS এর প্রভাব বাড়ে।

সমাধান: একটি SecurityHeaders মিডলওয়্যার বানিয়ে web ও api গ্রুপে যোগ করুন। CSP প্রথমে Report-Only মোডে চালিয়ে ভাঙা অংশ ঠিক করে তারপর enforce করুন (Livewire/Alpine এর জন্য nonce লাগবে, inline স্ক্রিপ্ট ও Vite dev সার্ভার মাথায় রাখুন)।

```
public function handle($request, Closure $next)
{
    $r = $next($request);
    $r->headers->set('X-Content-Type-Options', 'nosniff');
    $r->headers->set('X-Frame-Options', 'SAMEORIGIN');
    $r->headers->set('Referrer-Policy', 'strict-origin-when-cross-origin');
    $r->headers->set('Permissions-Policy', 'camera=(), microphone=(), geolocation=()');
    if (app()->isProduction()) {
        $r->headers->set('Strict-Transport-Security', 'max-age=31536000;
includeSubDomains');
    }
    $r->headers->set('Content-Security-Policy-Report-Only', "default-src 'self'; frame-
ancestors 'self'; ...");
    return $r;
}
```

সমস্যা ৩: পাবলিক ফর্মে থ্রটল ও ক্যাপচা নেই (ঝুঁকি: মাঝারি)

POST /contacts, /request-demo, /book-demo, /subscribers, /vouchers, /orders, /chat/messages এ কোনো throttle দেখা যায়নি, আর ক্যাপচা (reCAPTCHA/Turnstile সেটিংস আছে) এই API তে প্রয়োগ হয়নি। প্রতিটি Contact তৈরি হলে সব অ্যাডমিন নোটিফিকেশন পায় (আগের রিপোর্টের সাথে সম্পর্কিত), তাই স্ক্রিপ্ট দিয়ে হাজার হাজার ফর্ম পাঠিয়ে অ্যাডমিনদের ইনবক্স ও কিউ ভরানো সম্ভব। Contact এর message ফিল্ডে max নেই, ফলে বিশাল পেলোডও যায়।

সমাধান:

- প্রতিটি পাবলিক POST এ throttle (যেমন contacts: 5/মিনিট ও 30/ঘণ্টা প্রতি IP, RateLimiter::for দিয়ে নামযুক্ত লিমিটার)।
- বিদ্যমান Turnstile/reCAPTCHA যাচাই সার্ভার সাইডে এই এন্ডপয়েন্টগুলোতে বাধ্যতামূলক করুন।
- message এ max:5000, honeypot ফিল্ড যোগ করুন।
- অ্যাডমিন নোটিফিকেশন ব্যাচ/ডিবাউন্স করুন (প্রতি মিনিটে একবার সারাংশ)।

সমস্যা ৪: অর্ডার লুকআপে রেট লিমিট নেই (ঝুঁকি: মাঝারি)

GET /orders/{orderNumber}?email= শুধু অর্ডার নম্বর ও ইমেইল মেলালেই কাস্টমারের নাম, ঠিকানা, ফোন ও আইটেম দেখায়। লগইন লাগে না এবং throttle নেই। ইমেইল জানা থাকলে অর্ডার নম্বর অনুমান করে ব্রুট ফোর্স করা যায় (ORD-XXXXXXXX র‍্যাঙ্ডম হলেও সীমা নেই), আর ওয়ারেন্টি ডাউনলোড একই পদ্ধতির।

সমাধান: throttle:10,1 (IP + order number কী সহ), ব্যর্থ চেষ্টায় একই বার্তা (404) দিন, এবং সম্ভব হলে প্রতিক্রিয়ায় ফোন/ঠিকানা আংশিক মাস্ক করুন বা ইমেইলে পাঠানো সাইন করা লিংক ব্যবহার করুন।

সমস্যা ৫: Sanctum টোকেন কখনো মেয়াদোত্তীর্ণ হয় না (ঝুঁকি: মাঝারি)

config/sanctum.php এ expiration = null, তাই একবার ফাঁস হওয়া API টোকেন (ফোন হারালে, লগ বা ক্যাশে থাকলে) চিরকাল কাজ করে, অ্যাডমিন টোকেন হলে আরও ঝুঁকিপূর্ণ।

সমাধান: expiration সেট করুন (যেমন ৪৩২০০ মিনিট = ৩০ দিন), অ্যাডমিন টোকেনের জন্য ছোট মেয়াদ ও abilities (createToken('x', ['admin'], now()->addHours(8))), পাসওয়ার্ড বদলালে সব টোকেন বাতিল, নিয়মিত sanctum:prune-expired শিডিউল।

সমস্যা ৬: অ্যাডমিন = সার্ভারে কোড চালানোর ক্ষমতা (ঝুঁকি: মাঝারি, ডিজাইন সংক্রান্ত)

প্লাগইন ও থিম জিপ ইনস্টলে যেকোনো PHP (routes.php, migrations, Controllers) সার্ভারে বসে ও চলে। FileManager.php ফাইল ঠেকালেও প্লাগইন ইনস্টলার সেই নীতি এড়িয়ে যায়। অর্থাৎ একটি admin অ্যাকাউন্ট কমপ্রোমাইজ হলে (বা সমস্যা ১ এর XSS দিয়ে) সরাসরি সার্ভার দখল সম্ভব। এটি এই ধরনের CMS এ স্বাভাবিক, তবে ঝুঁকি কমানো দরকার।

সমাধান:

- admin অ্যাকাউন্টে MFA বাধ্যতামূলক রাখুন (EnsureMfaEnforced আছে, প্রোডাকশনে সক্রিয় ও অ্যাডমিনের জন্য বাইপাসযোগ্য নয় কিনা যাচাই করুন)।
- প্রোডাকশনে কনফিগ ফ্ল্যাগ (যেমন ALLOW_PLUGIN_UPLOAD=false) দিয়ে জিপ আপলোড ইনস্টল বন্ধ রাখুন; কোড ডিপ্লয় পাইপলাইনের মাধ্যমে আসুক।
- ইনস্টলের আগে নিশ্চিতকরণ + পুনরায় পাসওয়ার্ড চাওয়া, এবং AdminActivity এ লগ (আছে কিনা যাচাই) ও অ্যালার্ট।
- শুধু বিশ্বস্ত উৎসের জিপ, সম্ভব হলে checksum/signature যাচাই।

সমস্যা ৭: Custom Head/Body কোড (ঝুঁকি: নিম্ন)

custom_head_code ও custom_body_code Setting থেকে সরাসরি {!! !!} এ প্রিন্ট হয়, ফলে অ্যাডমিন যেকোনো JS বসাতে পারে। এটি ইচ্ছাকৃত ফিচার (analytics ট্যাগ) এবং শুধু access-admin-system এ সীমাবদ্ধ, কিন্তু অ্যাডমিন কমপ্রোমাইজ হলে চেকআউটে কার্ড স্কিমার বসানো যায়।

সমাধান: CSP (সমস্যা ২) দিয়ে অনুমোদিত ডোমেইনের তালিকা, এই সেটিং বদলালে লগ ও ইমেইল অ্যালার্ট, চেকআউট/অ্যাকাউন্ট পেজে কাস্টম কোড বাদ দেওয়ার অপশন।

সমস্যা ৮: .env এডিটরে newline ইনজেকশন (ঝুঁকি: নিম্ন)

EnvFile::quote() ভ্যালুর ভেতরের " ও \ এক্সেপ করে, কিন্তু \n ও \r নয়। ভ্যালুতে নতুন লাইন দিলে ফাইলে অতিরিক্ত লাইন ঢুকে অন্য কী (যেমন APP_DEBUG=true) সেট করা যেতে পারে। শুধু admin এর পক্ষে সম্ভব, তাই নিম্ন ঝুঁকি।

সমাধান: Env\Index এর ভ্যালিডেশনে নিয়ম যোগ করুন (regex:/^[^\r\n\0]*\$/) এবং EnvFile::set() এ কন্ট্রোল ক্যারেক্টার থাকলে RuntimeException ছুড়ুন। APP_DEBUG টগল প্রোডাকশনে লুকিয়ে বা নিষ্ক্রিয় রাখুন।

সমস্যা ৯: কনফিগারেশন হার্ডেনিং (ঝুঁকি: নিম্ন)

- APP_ENV=developer একটি স্বীকৃত মান নয়। app()->isProduction() মিথ্যা হওয়ায় শক্ত পাসওয়ার্ড নিয়ম (Password::defaults) ও অন্যান্য প্রোডাকশন-শর্তযুক্ত আচরণ কাজ করবে না। লাইভ সার্ভারে APP_ENV=production ও APP_DEBUG=false নিশ্চিত করুন।
- .env.example এ SESSION_ENCRYPT=false ও SESSION_SECURE_COOKIE নেই। প্রোডাকশনে SESSION_SECURE_COOKIE=true, SESSION_SAME_SITE=lax, SESSION_HTTP_ONLY=true রাখুন।
- পাসওয়ার্ড নিয়ম প্রোডাকশনে শক্ত হলেও (Password::defaults এ বিধান আছে), ন্যূনতম ১২ অক্ষর ও compromised পাসওয়ার্ড চেক (uncompromised()) রাখুন।
- Chunked upload ডিনাই-লিস্ট (ব্লকলিস্ট) নির্ভর। নতুন বিপজ্জনক এক্সটেনশন বাদ পড়তে পারে, তাই অনুমোদিত এক্সটেনশনের allowlist ও সার্ভারে MIME যাচাই (finfo) ভালো।

৪. যা যাচাই করা হয়নি (পরবর্তী ধাপ)

- ফ্রন্টএন্ড (codeware-frontend, Next.js) ও npm audit।

- Livewire অ্যাডমিন কম্পোনেন্টগুলোর প্রতিটির public প্রপার্টি টেম্পারিং ও per-action অথরাইজেশন (ফাইল ম্যানেজার ছাড়া বাকি)।
- পেমেন্ট গেটওয়ে/ওয়েবহুক ইন্টিগ্রেশন (কোনো webhook রুট পাওয়া যায়নি, গেটওয়ে ফ্লো যাচাই বাকি)।
- ডাটাবেস ব্যাকআপ ফাইল কোথায় থাকে ও কে ডাউনলোড করতে পারে (Backup, DatabaseDumper)।
- ওয়েব সার্ভার/ফায়ারওয়াল/TLS কনফিগ, ফাইল পারমিশন, স্টোরেজ লিংক।
- পাবলিক চ্যাট API (guest conversation resolve) এর টোকেন/সেশন বাঁধাই যাচাই।

৫. অগ্রাধিকার ও বাস্তবায়ন ক্রম

ধাপ	কাজ	চেপ্টা	ঝুঁকি কমে
১	HTMLPurifier যোগ + @richtext + পুরোনো ডাটা ক্লিন (সমস্যা ১)	১ দিন	উচ্চ
২	SecurityHeaders মিডলওয়্যার, CSP Report-Only (সমস্যা ২)	০.৫ দিন	উচ্চ
৩	পাবলিক POST এ throttle + captcha + max (সমস্যা ৩, ৪)	০.৫ দিন	মাঝারি
৪	Sanctum expiration ও abilities (সমস্যা ৫)	২ ঘণ্টা	মাঝারি
৫	প্রোডাকশনে প্লাগইন আপলোড ফ্ল্যাগ ও MFA যাচাই (সমস্যা ৬)	২ ঘণ্টা	মাঝারি
৬	EnvFile ভ্যালিডেশন, কনফিগ হার্ডেনিং (সমস্যা ৮, ৯)	২ ঘণ্টা	নিম্ন
৭	CSP enforce করা ও Custom code অ্যালার্ট (সমস্যা ২, ৭)	১ দিন	মাঝারি

৬. যাচাই (Verification)

- XSS টেস্ট: Pest এ পণ্যের description এ `<script>alert(1)</script>` ও `<img onerror=...>` সেভ করে নিশ্চিত করুন আউটপুটে নেই।
- হেডার টেস্ট: ফিচার টেস্টে `get('/')->assertHeader('X-Content-Type-Options', 'nosniff')` ইত্যাদি।
- থটল টেস্ট: ৬ষ্ঠ রিকোয়েস্টে ৪২৯ আসে কিনা (contacts, orders.show)।
- টোকেন টেস্ট: মেয়াদোত্তীর্ণ টোকেনে ৪০১।
- বাইরের স্ক্যান: OWASP ZAP বা Mozilla Observatory দিয়ে স্টেজিং স্ক্যান; নিয়মিত composer audit ও npm audit CI তে।
- পুনরায় অডিট: উপরের ধাপগুলোর পর এই রিপোর্ট আপডেট করুন।